

SOX Compliance Package

IT General Control Design, Testing Procedures, Evidence Collection & Audit
Readiness

Confidential — Internal Use | Generated 2026-08-21

SOX Compliance Package — IT General Control Design

Confidential — Internal Use | Prepared for: Controller's Office, Internal Audit, External
Auditors | 2026-08-21

1. Purpose & Scope

This document is the control-design package supporting management's assessment of Internal Control over Financial Reporting (ICFR) under Section 404 of the Sarbanes-Oxley Act (SOX), scoped to the IT General Controls (ITGCs) that support in-scope financial applications. It is built as code: every control, mapping, test procedure, and evidence requirement is generated from version-controlled source (`sox/*.py`) rather than maintained as static spreadsheets, so the design package, test procedures, and evidence matrix cannot drift out of sync.

In scope:

- The 9 IT General Controls in the organization's SOX control catalog (`sox/itgc_catalog.py`), spanning Access Management, Segregation of Duties, Access Reviews, Change Management, and Monitoring / Computer Operations.
- The mapping of those controls to all 17 COSO 2013 Internal Control — Integrated Framework principles across its 5 components.
- Financially significant applications: the general ledger, sub-ledgers (AP, AR, fixed assets), and the interfaces and infrastructure that support financial close.

Out of scope: application-level (automated business process) controls — e.g., three-way match, journal entry approval workflows — are assessed separately by the Controller's Office as part of the process-level control matrix. This package covers only the IT General Controls that those application controls rely on for reliable operation.

2. Regulatory & Framework Basis

Basis	Relevance
SOX Section 404	Requires management to assess and report on the effectiveness of ICFR annually.
PCAOB AS 2201 / AS 2301	Auditing standards governing the integrated audit of ICFR and financial statements; both direct auditors to evaluate ITGCs that support automated controls and financially relevant data.
COSO 2013 Internal Control — Integrated Framework	The control framework management uses to design and assess ICFR; all 17 principles must be present and functioning for a component to be deemed effective.

3. COSO 2013 Framework — Component Summary

The full 17-principle mapping (every principle, its design status, gap rating, and mapped ITGC(s)) is generated by `sox/coso-controls.py` into `outputs/coso-mapping.xlsx` / `outputs/coso-mapping.md`. Component-level summary:

Component	Principles	Directly ITGC-Mapped	Notes
Control Environment	P1–P5	2 of 5	P3 (structure/authority) and P5 (accountability) map to access-management controls; P1, P2, P4 are entity-level.

Component	Principles	Directly ITGC- Mapped	Notes
Risk Assessment	P6–P9	3 of 4	P7 (risk ID), P8 (fraud risk), and P9 (significant change) map to change management and SoD controls.
Control Activities	P10–P12	3 of 3	The ITGC catalog's core home — every control maps to P10 and P11 by definition.
Information & Communication	P13–P15	2 of 3	P13 (quality information) and P14 (internal communication) map to monitoring and review controls; P15 is entity-level (external auditor communication).
Monitoring Activities	P16–P17	2 of 2	Both principles map to UAR, emergency-change review, and security/log monitoring controls.

12 of 17 principles map directly to one or more ITGCs. The remaining 5 are entity-level controls (ethics, board oversight, competence, objective-setting, external communication) owned by the Controller's Office, HR, and the Audit Committee, and are tracked in the company-level control matrix rather than this ITGC-focused package.

4. IT General Controls Catalog

Full design detail — description, owner, control type, frequency, automation level, risk rating, and implementation status — is generated by `sox/it-general-controls.py` into `outputs/it-controls-design.xlsx` (see the **Dashboard** sheet for the current compliance status rollup) and `outputs/it-controls-design.md`.

Control ID	Title	ITGC Area	Owner	Risk Rating
SOX-ITGC-001	User Access Provisioning (New Hire / Role Change)	Authorization	IT Security / IAM Team	High
SOX-ITGC-002	User Access Deprovisioning (Termination / Role Change)	Authorization	IT Security / IAM Team	Critical
SOX-ITGC-003	Privileged / Administrative Access Management	Authorization	IT Security	Critical
SOX-ITGC-004	Segregation of Duties (SoD) — Financial Systems	Authorization	IT Security / Controller's Office	High

Control ID	Title	ITGC Area	Owner	Risk Rating
SOX-ITGC-005	Periodic User Access Review (UAR)	Access Reviews	Business System Owners / IT Security	High
SOX-ITGC-006	Program / Application Change Management	Change Management	IT Change Mgmt / App Development	High
SOX-ITGC-007	Emergency Change Management	Change Management	IT Change Management	Medium
SOX-ITGC-008	Security Configuration & Log Monitoring	Monitoring	IT Security / SOC	Medium
SOX-ITGC-009	Batch Job & Backup Monitoring (Computer Operations)	Monitoring	IT Operations	Medium

Design rationale by domain

Authorization (SOX-ITGC-001 to 004). Access to financially relevant systems is the most common source of ICFR deficiency in ITGC populations: a user who can create and approve their own transactions, or who retains access after leaving the company, can override every downstream application control. These four controls are rated High/Critical accordingly and are the first controls tested each quarter.

Access Reviews (SOX-ITGC-005). The UAR is the detective backstop for provisioning and deprovisioning — it catches what preventive controls missed (a manager who forgot to submit a termination ticket, an access grant that outlived its business justification).

Change Management (SOX-ITGC-006, 007). Uncontrolled changes to financial applications can silently alter calculation logic, reporting logic, or the effectiveness of other ITGCs. The standard and emergency change paths are both in scope because an emergency-only testing approach would miss changes deliberately routed around the standard gate.

Monitoring (SOX-ITGC-008, 009). These are largely automated, continuously operating controls; testing focuses on confirming the automation is configured correctly and that exceptions it surfaces are actually reviewed and resolved by a human, not just logged.

5. Control Ownership

Domain	Primary Owner	Escalation Path
Access Management (001–003)	IT Security / IAM Team	CISO → Controller's Office
Segregation of Duties (004)	IT Security / Controller's Office	Controller's Office → Audit Committee
Access Reviews (005)	Business System Owners	System Owner → IT Security → Controller's Office
Change Management (006–007)	IT Change Management	Change Advisory Board → Controller's Office
Monitoring (008–009)	IT Security (SOC) / IT Operations	IT Operations Manager → CISO

6. Testing Approach

Design and operating-effectiveness testing for every control follows the procedures in `docs/Testing-Procedures.md` (full detail generated to `outputs/test-procedures.md` by `sox/test-procedures.py`). In summary: interim testing occurs quarterly for controls that operate continuously or on a recurring cycle, with a year-end roll-forward covering any period not captured by interim testing; controls that are inherently periodic (UAR, SoD analysis, emergency-change reconciliation) are tested each time they run.

7. Deficiency Evaluation & Escalation

Exceptions identified during testing are evaluated for severity (control deficiency, significant deficiency, or material weakness) per the Controller's Office deficiency evaluation framework, considering: the magnitude of potential misstatement, the pervasiveness of the control across the financial statements, and whether compensating controls reduce the risk to an acceptable level. Deficiencies rated significant or above are reported to the Audit Committee no later than the next scheduled quarterly meeting; see `docs/Audit-Readiness.md` for current open-item status.

8. Cross-Reference

Deliverable	Generator	Output
COSO principle mapping	<code>sox/coso-controls.py</code>	<code>outputs/coso-mapping.xlsx</code> , <code>outputs/coso-mapping.md</code>

Deliverable	Generator	Output
ITGC design + compliance dashboard	sox/it-general-controls.py	outputs/it-controls-design.xlsx , outputs/it-controls-design.md
Test procedures manual	sox/test-procedures.py	outputs/test-procedures.md
Evidence collection matrix	sox/evidence-matrix.py	outputs/evidence-matrix.xlsx , outputs/evidence-matrix.md
Blank control-design template	templates/generate-control-template.py	templates/control-design-template.xlsx

SOX ITGC Testing Procedures Manual

Confidential — Internal Use | Prepared for: Internal Audit, Control Testers, External Auditors | 2026-08-21

1. Purpose

This manual defines the methodology used to test the design and operating effectiveness of the 9 IT General Controls in scope for SOX ICFR (see `docs/SOX-Control-Design.md`). It governs *how* controls are tested; the control-by-control test objective, sample-size approach, numbered steps, and expected results are generated by `sox/test-procedures.py` into `outputs/test-procedures.md` and should be used as the workpaper template for each testing cycle.

2. Testing Methods Used

Consistent with PCAOB guidance on evaluating ITGCs, testers apply one or more of the following methods per control, selected based on the nature of the control:

Method	When Used
Inquiry	Always performed, but never relied on alone — used to understand the control and corroborate other evidence.
Observation	Used for controls with a physical or real-time component (e.g., observing a badge-access exit process); limited use in this ITGC population.
Inspection of documentation	The primary method for this population — access tickets, approval records, change tickets, UAR sign-offs, configuration exports, and logs are inspected against the control's defined criteria.
Reperformance	Used where practical to independently validate a system-generated result (e.g., re-running the SoD conflict analysis for a sub-sample of users, per SOX-ITGC-004).

Design effectiveness (the control, as designed, would prevent or detect a material misstatement) is evaluated via a **walkthrough**: tracing one transaction/event end-to-end through the control and confirming the control point actually exists and operates as documented. Operating effectiveness (the control operated consistently as designed throughout the period) is evaluated via the sample-based procedures in `outputs/test-procedures.md`.

3. Sampling Standards

Sample sizes follow a standard attribute-sampling approach for controls operating more frequently than annually, calibrated to population size and control risk:

Population Size	Sample Size (controls operating > weekly)	Sample Size (controls operating monthly/quarterly)
< 25	100% (test full population)	100% (test full population)
25–250	25	Test every occurrence in the period
> 250	25 (statistically valid attribute sample; increase to 40–60 for Critical-rated controls with a low tolerable exception rate)	Test every occurrence in the period

Automated, system-enforced controls with no manual override path (e.g., an SoD rule engine that blocks conflicting role assignment at the point of grant) may be tested with a single instance of design effectiveness testing plus a change-management/configuration-monitoring control over the rule engine itself, rather than a full population sample — but no control in this catalog currently qualifies for that reduced approach; all 9 are tested per the table above pending further automation maturity.

4. Roles & Independence

Role	Responsibility
Control Tester	Executes the test procedures in <code>outputs/test-procedures.md</code> , documents evidence obtained and conclusions reached, and is independent of the control's operation (does not perform or approve the activity being tested).
Testing Lead / Internal Audit Manager	Reviews completed workpapers for sufficiency of evidence and appropriateness of conclusions; approves exception write-ups.
Control Owner	Provides evidence access, responds to tester inquiries, and is accountable for remediating exceptions — but does not test their own control.
External Auditor	Independently reperforms a subset of testing (per the integrated audit plan) and relies on management's testing where the auditor's own risk assessment supports reliance.

5. Workpaper Documentation Standards

Every completed test must retain, at minimum: (1) the population and how completeness was verified, (2) the sample selected and the basis for selection, (3) the evidence obtained per sample item, (4) the conclusion for each item (pass/exception), (5) a description of any exception and its disposition, and (6) the tester's name, review date, and reviewer sign-off. Workpapers are retained for **7 years** (see `docs/Evidence-Collection.md`) in the GRC evidence repository.

6. Testing Cadence Summary

Control ID	Test Type	Frequency
SOX-ITGC-001	Design & Operating Effectiveness	Quarterly interim + year-end roll-forward
SOX-ITGC-002	Design & Operating Effectiveness	Quarterly interim + year-end roll-forward
SOX-ITGC-003	Design & Operating Effectiveness	Quarterly
SOX-ITGC-004	Design & Operating Effectiveness	Quarterly
SOX-ITGC-005	Design & Operating Effectiveness	Quarterly
SOX-ITGC-006	Design & Operating Effectiveness	Quarterly interim + year-end roll-forward
SOX-ITGC-007	Design & Operating Effectiveness	Quarterly
SOX-ITGC-008	Design & Operating Effectiveness	Continuous automated monitoring + quarterly sample test
SOX-ITGC-009	Design & Operating Effectiveness	Daily automated monitoring + quarterly sample test + quarterly restore test

For the full test objective, sample-size approach, numbered test steps, and expected results per control, see `outputs/test-procedures.md` (generated by `sox/test-procedures.py`). Use `templates/test-procedure-template.md` as the blank workpaper to document each execution.

SOX ITGC Evidence Collection Guidance

Confidential — Internal Use | Prepared for: Control Owners, Internal Audit, External Auditors | 2026-08-21

1. Purpose

This guidance tells control owners and testers what evidence is required to demonstrate each IT General Control operated, where to obtain it, and how long it must be retained. The authoritative, control-by-control matrix is generated by `sox/evidence-matrix.py` into `outputs/evidence-matrix.xlsx` / `outputs/evidence-matrix.md`; this document explains the principles behind it and the collection process.

2. What Makes Evidence Sufficient

Evidence supporting a SOX control must be:

- **Contemporaneous** — generated at or near the time the control activity occurred, not reconstructed afterward. A UAR sign-off dated after the review period closed is not sufficient evidence the review happened on time.
- **Attributable** — identifies who performed the activity (requestor, approver, reviewer) by name or unique system identifier, not a shared account.
- **Independently verifiable** — pulled from a system of record (ticketing system, HRIS, IAM platform, SIEM, job scheduler) rather than a manually maintained tracking sheet, wherever an automated source exists.
- **Complete for the population** — testers must be able to verify the evidence represents the *full* population for the period (e.g., a ticketing-system export can be reconciled to a system-generated count), not a hand-picked subset.

3. Collection Process

1. **Identify the requirement.** Look up the control in `outputs/evidence-matrix.xlsx` to find the evidence ID(s), what's required, and who owns producing it.

2. **Pull from the system of record.** Evidence owners export directly from the source system (ITSM, HRIS, IAM, SIEM, job scheduler, change management, backup platform) — see the "How to Collect" column in the matrix for the specific export path per item.
3. **Redact only what's required.** Evidence may be redacted for unrelated sensitive data (e.g., other employees' compensation visible in an HRIS export) but must never be redacted in a way that removes the attribution or timestamp fields testers need.
4. **Upload to the evidence repository.** All evidence is stored in the GRC evidence repository under the relevant control ID and testing period, not in local drives or email, so it remains available for both internal testing and the external audit PBC (Provided By Client) process.
5. **Log the submission.** The evidence repository tracks submission date and evidence owner automatically; overdue evidence requests escalate per the SLA in Section 5.

4. Retention

All SOX ITGC evidence is retained for **7 years**, aligned to SOX Section 802 record-retention requirements and SEC Rule 17a-4 practice. Evidence is retained in the GRC evidence repository with access restricted to Internal Audit, the relevant control owner, and External Audit during the audit engagement window. Evidence is never deleted ahead of the retention date, including for controls later retired or redesigned — historical testing periods must remain supportable.

5. Evidence Request SLA

Request Type	SLA to Provide
Standard quarterly testing evidence (interim)	5 business days from request
Year-end roll-forward evidence	5 business days from request
External auditor PBC request	3 business days from request (per the audit engagement letter)
Ad hoc / follow-up on an exception	2 business days from request

Evidence not received within the SLA is escalated by the tester to the control owner's manager; a pattern of missed SLAs is itself logged as a monitoring observation against SOX-ITGC control ownership.

6. Evidence Matrix Summary

20 evidence artifacts are mapped across the 9 in-scope ITGCs — full detail (evidence ID, description, collection method, owner, storage location) is in `outputs/evidence-matrix.xlsx` and `outputs/evidence-matrix.md`. Every control has at least two independent evidence artifacts so that testing does not rely on a single source.

ITGC Area	Controls	Evidence Items
Authorization	SOX-ITGC-001–004	9
Access Reviews	SOX-ITGC-005	2
Change Management	SOX-ITGC-006–007	4
Monitoring	SOX-ITGC-008–009	4

7. Storage & Access Security

The GRC evidence repository enforces role-based access (Internal Audit, control owners for their own control's evidence, and External Audit during the active engagement window only), full audit logging of access and downloads, and encryption at rest — evidence about who has access to financial systems is itself sensitive and is protected accordingly.

SOX ITGC Audit Readiness Checklist

Confidential — Internal Use | Prepared for: Controller's Office, Internal Audit, External Auditors | 2026-08-21

1. Overall Readiness

As of 2026-08-21: **5 of 9** ITGCs implemented, **6 of 9** design-effectiveness tested, **4 of 9 (44%)** operating-effectiveness tested. Live status and the per-control RAG (Red/Amber/Green) view are in the **Dashboard** sheet of `outputs/it-controls-design.xlsx`, generated by `sox/it-general-controls.py`.

Status	Count
Implemented	5
In Progress	4
Planned / Not Started	0

2. Program-Level Readiness Checklist

- ☒ ITGC catalog defined and approved (9 controls; `sox/itgc_catalog.py`)
- ☒ COSO 2013 principle mapping complete (17 of 17 principles addressed; 12 mapped directly to ITGCs)
- ☒ Test procedures documented for all 9 controls (`outputs/test-procedures.md`)
- ☒ Evidence collection matrix defined for all 9 controls (`outputs/evidence-matrix.xlsx`)
- ☒ Control ownership assigned and confirmed with each owner
- ☐ Design-effectiveness walkthrough completed for all 9 controls (6 of 9 complete — see Section 3)
- ☐ Operating-effectiveness testing completed for all 9 controls (4 of 9 complete — see Section 3)
- ☐ SoD conflict rule set formally re-approved within the last 12 months (SOX-ITGC-004 — in progress)
- ☐ Security configuration baseline formally re-approved (SOX-ITGC-008 — in progress)
- ☐ All prior-period exceptions remediated or have an accepted risk-acceptance on file

- [] Deficiency evaluation memo drafted for any control rated High/Critical risk with open testing
- [] External auditor PBC list issued and evidence-repository access provisioned for the audit window
- [] Quarterly control status reviewed with the Controller's Office
- [] Annual ICFR assessment package assembled for management sign-off

3. Per-Control Readiness

Control ID	Design Tested	Operating Tested	Evidence on File	Ready for Audit?
SOX-ITGC-001	Yes	Yes		Ready
SOX-ITGC-002	Yes	No		Partial — operating test scheduled
SOX-ITGC-003	Yes	No		Partial — operating test scheduled
SOX-ITGC-004	No	No		Not ready — SoD rule set expansion in progress
SOX-ITGC-005	Yes	Yes		Ready
SOX-ITGC-006	Yes	Yes		Ready
SOX-ITGC-007	Yes	No		Partial — operating test scheduled
SOX-ITGC-008	No	No		Not ready — baseline re-approval pending
SOX-ITGC-009	Yes	Yes		Ready

4. Open Items & Target Close Dates

Item	Control	Owner	Target Date
Complete operating-effectiveness test		IT Security / IAM Team	2026-09-15

Item	Control	Owner	Target Date
	SOX-ITGC-002		
Complete operating-effectiveness test	SOX-ITGC-003	IT Security	2026-09-15
Expand SoD conflict rule coverage (vendor master + payment conflicts) and complete design walkthrough	SOX-ITGC-004	IT Security / Controller's Office	2026-09-30
Complete operating-effectiveness test	SOX-ITGC-007	IT Change Management	2026-09-15
Re-approve security configuration baseline and complete design walkthrough	SOX-ITGC-008	IT Security	2026-09-30
Formalize delegation-of-authority matrix for system ownership (COSO P3)	Entity-level	Controller's Office	2026-10-15
Formalize deficiency-escalation path to Audit Committee (COSO P17)	Entity-level	Internal Audit	2026-10-15

5. Sign-Off

Role	Name	Date
Control Owner (per control)	<i>see individual control sign-off in evidence repository</i>	
Internal Audit Manager		
Controller		
Chief Information Security Officer		

This checklist is a point-in-time snapshot. Re-run `sox/it-general-controls.py` after each testing cycle to regenerate the Dashboard sheet with current status, and update this document's Sections 1, 3, and 4 to match.